COMPTIA SECURITY+ SY0-701 | DOMAIN 1 · GENERAL SECURITY CONCEPTS (12%)

Security+ 1.2 · The CIA Triad

Mestre CyberSec · **Lesson 1.2 — The CIA Triad** (5:17) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: 3 objetivos: CONFIDENCIALIDADE (só quem deve, vê — encriptação, ACL, MFA, classificação); INTEGRIDADE (dado não é alterado indevidamente — hash, assinatura digital, certificado); DISPONIBILIDADE (serviço up — redundância, failover, patch, backup). Todo controle serve a pelo menos

💡 Key Exam Highlights & Critical Concepts

- C ferida: leak/escuta. I ferida: alterado/fraudado. A ferida: serviço down.
- Hash dá I, NÃO C (não cifrar conteúdo)
- Assinatura digital dá I + autenticação + non-repudiation (o 3-em-1)
- AES = confidencialidade; RSA = troca de chave + assinatura
- 'which of the three goals was COMPROMISED' = a pergunta clássica

🎯 Exam Tips & Typical CompTIA Scenarios

- Cenário 'alguém viu o dado'=C · 'alguém alterou'=I · 'não consigo acessar'=A
- Cuidado: 'email enviado por personagem não-autorizado' pode ser I (integridade do remetente) ou C se o conteúdo vazou

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 1.2 — The CIA Triad)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• CIA Triad

The foundational security model consisting of three core goals: Confidentiality, Integrity, and Availability. Every security control maps to at least one of these objectives.

⚠️ ***Exam Trap:*** *If a question asks 'which CIA goal was compromised?', match the symptom: data exposed/viewed = Confidentiality; data altered/falsified = Integrity; service down/unreachable = Availability.*

• Confidentiality

Ensures that data is only accessible to authorized parties. Implemented via encryption, access control lists (ACLs), MFA, and data classification.

⚠️ ***Exam Trap:*** *CompTIA trigger: 'data leaked, intercepted, or viewed by the wrong person' = Confidentiality breach. Controls: encryption, classification, ACL.*

• Integrity

Ensures data has not been modified or tampered with, whether at rest or in transit. Implemented using hashing, digital signatures, and certificates.

⚠️ ***Exam Trap:*** *CompTIA trigger: 'data altered, falsified, or modified by an unauthorized party' = Integrity breach. Hash is the #1 control tested here.*

• Availability

Ensures systems and data remain accessible to authorized users when needed. Implemented via redundancy, failover, patching, and backups.

⚠️ ***Exam Trap:*** *CompTIA trigger: 'service down, unreachable, DoS, or system offline' = Availability breach. Controls: redundancy, failover clusters, UPS, patching.*

• Hash (Cryptographic Hash) (N/A)

A one-way mathematical function that produces a fixed-size output (digest) representing the input data, used to verify Integrity — not Confidentiality.

⚠ ***Exam Trap:*** *KEY DISTINCTION: Hashing provides Integrity ONLY. It does NOT provide Confidentiality because the original data is still visible/readable — the hash only detects changes. Common algorithms: MD5, SHA-256.*

• Digital Signature (DS)

A cryptographic operation using asymmetric keys that provides Integrity, Authentication, and Non-repudiation in a single mechanism — the '3-in-1' security control.

⚠ ***Exam Trap:*** *CompTIA loves this combo: Digital Signature = Integrity + Authentication + Non-repudiation. If a question lists all three benefits, the answer is Digital Signature, not just hashing or encryption.*

• Non-Repudiation (NR)

The assurance that a sender cannot deny having sent a message or performed an action. Achieved through digital signatures and cryptographic audit trails.

⚠ ***Exam Trap:*** *Non-repudiation is unique to digital signatures and PKI — neither encryption nor hashing alone provides it. Watch for it bundled with Integrity and Authentication in answer choices.*

• Encryption (AES / RSA)

AES (symmetric) provides Confidentiality by scrambling data with a shared key. RSA (asymmetric) is used for key exchange and digital signatures — not bulk data encryption.

⚠ ***Exam Trap:*** *AES = Confidentiality ONLY. RSA = key exchange + digital signatures. The exam often asks 'which provides confidentiality?' — symmetric ciphers like AES are the answer, not hashing.*

🏛 Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Confidentiality: Protecting Against Unauthorized Disclosure

🏠 **Real-World Analogy:** An ultra-sensitive diplomatic letter written in ciphertext, sealed inside an opaque tamper-evident security envelope, locked inside a heavy safe to which only you hold the combination. Anyone walking down the hallway or handling the envelope cannot read a single word of its contents.

🔍 **Root Cause & Background:** On shared network backbones and multi-tenant storage, data packets and files in transit or at rest can easily be captured by packet sniffers or exfiltrated by malicious actors if transmitted in unencrypted plaintext.

🛡 **GRC Auditor Perspective:** Auditors ensure compliance with data privacy regulations (GDPR, HIPAA, PCI-DSS): checking that data at rest is protected via AES-256 encryption, data in transit mandates TLS 1.3, and data classification schemas paired with Role-Based Access Control (RBAC) restrict access strictly on a need-to-know basis.

⚠ **How CompTIA Tests This:** Exam cues: 'Snooping', 'Packet sniffing', 'Eavesdropping', 'Data breach / exfiltration', 'Unauthorized reading of payroll files'. Compromised pillar: Confidentiality. Primary controls: Encryption (AES), Access Control Lists, MFA, Data Loss Prevention (DLP).

📌 Integrity: Guaranteeing Accuracy and Tamper-Resistance

🏠 **Real-World Analogy:** The tamper-evident numbered seal on a ballot box or holographic security tape across a pharmaceutical bottle. If someone tampers with the container in transit to swap the medicine or manipulate records, the seal breaks irrevocably, instantly warning the recipient that integrity was compromised.

🔍 **Root Cause & Background:** Data packets and system binaries traversing networks are vulnerable to transmission noise and malicious Man-in-the-Middle (MitM) tampering, where adversaries alter bank account destinations or inject trojans into legitimate application installers.

🛡 **GRC Auditor Perspective:** Auditors verify cryptographic hashing implementations (SHA-256), digital signatures, and automated File Integrity Monitoring (FIM) tools that immediately alert SOC analysts when system configuration files or core databases experience unauthorized modification.

⚠ **How CompTIA Tests This:** Exam cues: 'Attacker modifies financial payload in transit', 'Verify integrity of downloaded firmware', 'Ensure log files were not altered'. Compromised pillar: Integrity. Primary controls: Cryptographic Hashing (SHA-256), Digital Signatures, FIM. TRAP: Hashing provides integrity, NOT confidentiality!

📌 Availability: Timely and Reliable Access to Services and Data

🏠 **Real-World Analogy:** A hospital ICU powered by dual independent utility power grids, an on-site automatic diesel generator with reserve fuel, and redundant battery UPS units at every patient bed. If the municipal power grid suffers a total blackout, patient life-support systems continue operating without a microsecond of interruption.

🔍 **Root Cause & Background:** Hardware components fail, fiber cables get severed, natural disasters flood datacenters, and malicious botnets launch massive Distributed Denial of Service (DDoS) floods to saturate bandwidth and collapse corporate services.

🛡️ **GRC Auditor Perspective:** Auditors audit Business Continuity SLAs and Disaster Recovery metrics: evaluating RTO (Recovery Time Objective), RPO (Recovery Point Objective), redundancy architectures (RAID, load balancers, multi-region failover, UPS generators), and routine testing of the 3-2-1 backup strategy.

⚠️ **How CompTIA Tests This:** Exam cues: 'DDoS flooding bandwidth', 'Server hardware crash takes payroll offline', 'Power grid failure halts production'. Compromised pillar: Availability. Primary mitigations: Redundancy, High Availability (HA) clustering, Load Balancers, RAID, Failover, Offsite Backups.

📌 Balancing the CIA Triad: Security vs. Usability Trade-offs

🏠 **Real-World Analogy:** Imagine a bank safe secured by 15 separate deadbolts, three biometric iris scanners, and 40-character passphrases rotated hourly. Confidentiality is nearly absolute, but if an employee needs immediate emergency access to life-saving records, the extreme friction ruins availability and business operations.

🔍 **Root Cause & Background:** Overly cumbersome security measures create severe operational drag, tempting frustrated employees to bypass official protocols via unauthorized Shadow IT workarounds, ultimately defeating enterprise defense.

🛡️ **GRC Auditor Perspective:** In risk governance audits, auditors evaluate whether the operational friction and monetary expense of controls remain proportional to the organization's board-approved risk appetite (NIST CSF - Govern Function).

⚠️ **How CompTIA Tests This:** CompTIA exam emphasis: Security controls must balance risk reduction against business usability. Implementing controls so restrictive that legitimate business halts is a distractor; select solutions delivering balanced defense aligned with operational requirements.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Attacker sniffs open Wi-Fi packets and reads unencrypted plaintext passwords	**Breach of Confidentiality (Mitigation: WPA3 / TLS Encryption)**
Malware stealthily alters banking routing numbers in outgoing PDF invoices	**Breach of Integrity (Mitigation: SHA-256 Hashing / Digital Signatures)**
Volumetric DDoS flood renders e-commerce customer portal unreachable	**Breach of Availability (Mitigation: Redundancy / CDN / DDoS Scrubbing)**
A server hard drive fails, but the storage array continues operating without data loss	**Preservation of Availability (Mechanism: RAID & Hardware Redundancy)**
Validating SHA-256 checksum of an OS installer image downloaded from vendor	**Assurance of Integrity (Mechanism: Cryptographic Hash)**
Data classification and restricting confidential document access via RBAC	**Assurance of Confidentiality (Mechanism: Least Privilege & DLP)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A hospital's IT team discovers that a laptop loaned to a visiting auditor was stolen from a rental car. The laptop stored unencrypted spreadsheets containing patient names, diagnoses, and insurance ID numbers. To guarantee that whoever finds or purchases the stolen device cannot read the sensitive files, which control should the team deploy on all mobile laptops going forward?

A) Restrictive NTFS ACLs on the spreadsheet folders

B) Full-disk encryption using AES-256

C) Host-based firewall rules blocking inbound connections

D) Nightly backups replicated to an offsite data center

QUESTION 2 · EXAM SCENARIO

A systems administrator needs to download a large Linux distribution ISO while the vendor's primary site is offline, so she switches to a third-party mirror. She has the vendor's official SHA-256 digest from the vendor's verified announcements page. Which action gives her the strongest evidence that the downloaded ISO has not been modified or corrupted?

A) Verify the ISO opens without errors in the disc-burning utility

B) Encrypt the ISO with AES-256 before saving it

C) Compute the file's SHA-256 hash and compare it to the vendor's published digest

D) Confirm that the download session used TLS

QUESTION 3 · EXAM SCENARIO

During last year's holiday sale, the single web server hosting a retailer's checkout page crashed, and customers were unable to complete purchases for three hours. Management now demands a solution that prevents a single hardware failure from taking the storefront offline again. Which control directly meets this requirement?

A) Deploy a redundant server cluster with automatic failover

B) Require customers to complete MFA before checkout

C) Enable AES-256 encryption for all checkout traffic

D) Digitally sign every order confirmation with the company's private key

QUESTION 4 · EXAM SCENARIO

A procurement manager at a manufacturing company approved a large equipment order by sending the supplier a purchase order email. Weeks later she denies ever authorizing it, and the supplier demands proof. Going forward, the company wants purchase orders protected so the approver cannot later deny sending them and any modification to the document is detectable. Which control satisfies both requirements?

A) Encrypt each purchase order with a shared AES passphrase

B) Hash each purchase order and store the digest in a shared team folder

C) Transmit purchase orders only through an IPsec VPN tunnel

D) Digitally sign each purchase order with the approver's private key

QUESTION 5 · EXAM SCENARIO

After a phishing campaign, attackers successfully signed in to several finance department webmail accounts using harvested usernames and passwords. Password complexity requirements are already enforced and all sessions use TLS. Which control would most directly prevent authentication with stolen credentials alone?

A) Increase the minimum password length from 12 to 16 characters

B) Implement MFA requiring a TOTP code or hardware security key

C) Rotate the webmail portal to a stronger TLS cipher suite

D) Deploy a redundant mail server cluster for failover

QUESTION 6 · EXAM SCENARIO

A forensics team investigating an insider incident is concerned that an administrator with server access could quietly edit audit logs to erase the trail. Which control best ensures any tampering with stored logs will be detected?

A) Write logs to WORM storage and record rolling hashes of each entry

B) Encrypt the log files with AES-256 and keep the decryption keys on the same server

C) Configure RAID 6 on the log volume so it survives disk failures

D) Compress the logs nightly and archive them to an internal share

QUESTION 7 · EXAM SCENARIO

Ransomware encrypted a design studio's primary file server. Designers could not reach project files for most of the day until the operations team restored everything from the previous night's backup copies. Which objective of the CIA triad is most directly demonstrated by being able to restore service from backups?

A) Non-repudiation

B) Integrity

C) Availability

D) Confidentiality

QUESTION 8 · EXAM SCENARIO

An internal audit finds that payroll files on the company's HR server can be opened by employees from every department. The data is encrypted at rest and transferred over TLS. Which change directly ensures that only authorized HR staff can view the payroll data?

A) Apply ACLs that grant folder permissions only to the HR security group

B) Upgrade the at-rest cipher from AES-128 to AES-256

C) Configure active/passive failover nodes for the HR server

D) Publish a SHA-256 digest of each payroll file to the intranet

QUESTION 9 · EXAM SCENARIO

Developers are building a client portal that must securely exchange a symmetric key with each browser over the internet and then encrypt megabytes of uploaded documents per session. Which cryptographic approach best fits these requirements?

A) Encrypt each uploaded document directly with RSA, since asymmetric algorithms are always stronger

B) Use RSA to protect the symmetric session key exchange, and AES-256 to encrypt the uploaded documents

C) Hardcode one static AES key into every client build to eliminate the need for key exchange

D) Apply SHA-256 to each uploaded document and send the digest alongside the ciphertext

QUESTION 10 · EXAM SCENARIO

Employees install a vendor's management agent from the vendor's download portal. Security wants assurance that the installer is both unmodified and genuinely issued by the vendor, even if a partner mirror hosting the file is compromised. Which verification method provides this?

A) Confirm the download link uses HTTPS before saving the file

B) Compare the installer's file size against the size shown on the portal

C) Test the installer in a lab VM and confirm it launches without errors

D) Validate the installer's digital signature against the vendor's code-signing certificate

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option B — Full-disk encryption using AES-256

Full-disk encryption (e.g., AES-256 with TPM-bound keys) directly protects CONFIDENTIALITY: even if the thief removes the drive or boots another OS, the data remains unreadable without the key. NTFS ACLs (A) restrict access through the running OS but are bypassed by booting from external media or reading the disk attached to another machine. Firewall rules (C) only filter network traffic and do nothing for an offline, stolen device. Nightly backups (D) support Availability and recovery, not secrecy of data on a stolen laptop.

Question 2: Option C — Compute the file's SHA-256 hash and compare it to the vendor's published digest

Comparing the computed SHA-256 hash of the downloaded file against the vendor's published digest is the classic INTEGRITY verification: a change of even a single bit produces a completely different hash, exposing tampering or corruption. Opening the file in the burn utility (A) only confirms it launches, not that its content is authentic. AES-256 encryption (B) provides confidentiality, not integrity. TLS (D) protects the transfer in transit but cannot reveal that a compromised mirror is serving a replaced file.

Question 3: Option A — Deploy a redundant server cluster with automatic failover

A redundant cluster with automatic failover directly raises AVAILABILITY: if one node dies, another immediately serves the checkout page, eliminating the single point of failure that caused the outage. MFA (B) and AES-256 (C) are confidentiality/authentication controls that do nothing to keep the site running after hardware failure. Digitally signing confirmations (D) supports integrity and non-repudiation of orders, but not uptime.

Question 4: Option D — Digitally sign each purchase order with the approver's private key

A digital signature created with the approver's private key provides INTEGRITY (any alteration breaks the signature), authentication, and NON-REPUDIATION: the approver cannot credibly deny authorship because only her private key could have produced the valid signature. A shared AES passphrase (A) proves nothing about who created the document, since the key is shared. A bare hash in a shared folder (B) proves the content but does not bind it to the signer's identity. An IPsec VPN (C) protects confidentiality in transit but leaves no evidence of authorship afterward.

Question 5: Option B — Implement MFA requiring a TOTP code or hardware security key

MFA adds an independent second factor (something you have, such as a TOTP or hardware key), so a stolen password by itself is insufficient to authenticate; this is a direct confidentiality/authentication safeguard against credential theft. A longer password (A) raises the bar but is still a single factor the attackers already possess. Changing the TLS cipher suite (C) protects data in transit, not the abused login process. Redundant mail servers (D) are an Availability control with no bearing on stolen credentials.

Question 6: Option A — Write logs to WORM storage and record rolling hashes of each entry

WORM (write-once-read-many) storage prevents silent edits, and rolling hashes chain each log entry so that any modification changes the digest; this is the core INTEGRITY requirement for tamper-evident logging. AES-256 encryption (B) provides confidentiality, but the same administrator holds the keys on-server and can re-encrypt modified files. RAID 6 (C) defends Availability against disk loss while faithfully preserving (replicating) any malicious changes. Nightly compression and archiving (D) neither restrict writes nor detect modification.

Question 7: Option C — Availability

The defining question of AVAILABILITY is whether data and services are reachable when needed; backups, especially offline or immutable ones, are the primary recovery control that brings the service back after destruction or ransomware. Integrity (B) would be the concern if files had been silently modified and needed hash comparison to detect the change. Confidentiality (D) concerns keeping data secret, and non-repudiation (A) concerns proving who performed an action; neither describes what the restore demonstrated.

Question 8: Option A — Apply ACLs that grant folder permissions only to the HR security group

ACLs implementing least privilege restrict which accounts can open the payroll folder; access control on the shared server is the direct CONFIDENTIALITY fix for overbroad permissions. A longer AES key (B) only matters if an attacker has already bypassed authorization and holds the ciphertext; the exposure here is authorization, not key strength. Failover nodes (C) address Availability. Publishing SHA-256 digests (D) supports Integrity, letting recipients detect alterations, but does nothing to stop unauthorized reading.

Question 9: Option B — Use RSA to protect the symmetric session key exchange, and AES-256 to encrypt the uploaded documents

This is the standard hybrid cryptosystem: RSA (asymmetric) solves the secure key-exchange problem because only the holder of the private key can recover the session key, while AES-256 (symmetric) encrypts bulk data quickly at scale. Encrypting every document with RSA (A) is orders of magnitude slower and impractical for large files. A static AES key compiled into all clients (C) defeats the purpose of key exchange and collapses as soon as one client is compromised. SHA-256 (D) provides integrity verification of content, not confidentiality or key exchange.

Question 10: Option D — Validate the installer's digital signature against the vendor's code-signing certificate

A code-signing certificate lets any client verify the installer with the vendor's public key: the signature fails if even one byte changed (INTEGRITY), and the certificate chain proves the vendor's identity (authenticity), which survives a compromised mirror serving an altered binary. HTTPS (A) only encrypts the transfer; if the mirror itself is hostile, the malicious file arrives over a perfectly secure connection. File size (B) is trivial for an attacker to match. A successful launch in a lab VM (C) proves nothing about provenance; malware also launches.